

# Domain-Specific Contrastive Representation Learning Outperforms Generative LLMs and Hybrid Retrieval in Cross-Domain Compliance Mapping

James Pusateri

Middle Coast Software Inc.

[james.pusateri@middlecoastsoftware.com](mailto:james.pusateri@middlecoastsoftware.com)

## ABSTRACT

Correlating technical vulnerability disclosures with administrative cybersecurity controls is a central operational challenge in continuous compliance and risk management. Security analysts and compliance officers routinely spend significant manual effort mapping Common Vulnerabilities and Exposures (CVE) summaries to regulatory frameworks such as NIST Special Publication 800-53 and the Cybersecurity Maturity Model Certification (CMMC). General-purpose foundation models and zero-shot dense retrievers exhibit severe performance deficits on this task due to the structural vocabulary mismatch between technical vulnerability primitives (such as memory corruption or buffer overflows) and regulatory control objectives (such as input validation or boundary protection). In this work, we demonstrate that domain-specific contrastive fine-tuning of compact bi-encoder models using Multiple Negatives Ranking Loss (MNRL) produces superior retrieval accuracy compared to zero-shot foundation models, generative Large Language Model (LLM) rerankers, and lexical-dense hybrid search pipelines. Evaluated against a rigorous 2,000-sample validation dataset isolated from training data, a domain-tuned 110-million parameter encoder achieved a Strict Hit Rate @ 1 of 77.45%, a Strict Hit Rate @ 3 of 82.15%, and a Parent Control Roll-up Hit Rate @ 3 of 87.15%, compared to 0.30% Strict Hit Rate @ 1 for zero-shot BGE-Large and 0.10% for zero-shot GTE-Qwen2-7B. Crucially, downstream reranking using a 7-billion parameter generative model (Qwen2.5-7B-Instruct) degraded top-1 retrieval performance from 77.45% to 72.00%, while lexical hybrid search using BM25 Okapi and Reciprocal Rank Fusion caused strict top-1 accuracy to collapse to 13.65% as a consequence of lexical score poisoning. These empirical findings indicate that specialized contrastive geometry in compact embedding models is fundamentally more effective and computationally efficient for regulatory mapping than generative reasoning or lexical hybrid retrieval. The full model generation stack, training pipelines, evaluation harnesses, and conversion tooling have been released as open-source software under the Applied Inference Lab initiative.

## Disclosure and Funding

Middle Coast Software Inc. has elected to release this research, architecture, and associated toolchain as an open-source contribution to the cybersecurity and machine learning communities rather than pursue commercial monetization. No external funding, grants, or commercial sponsorships were received for this investigation.

## 1. Introduction

Regulatory cybersecurity frameworks, including NIST Special Publication (SP) 800-53 Revision 5 (Joint Task Force, 2020) and the United States Department of Defense Cybersecurity Maturity Model Certification (CMMC),

require organizations to continuously assess technical assets against formal security control catalogs. In operational environments, vulnerability scanning systems report findings identified by Common Vulnerabilities and Exposures (CVE) identifiers and Common Weakness Enumeration (CWE) classifications. To substantiate compliance and track remediation efficacy, system security officers must map each detected technical vulnerability to one or more relevant compliance controls.

Historically, this mapping has been conducted through manual review or simplistic keyword heuristics. Manual adjudication is labor-intensive, error-prone, and unsustainable given that thousands of new CVEs are published annually (NIST, 2026). However, naive automation using off-the-shelf information retrieval or modern generative artificial intelligence presents profound challenges. Technical vulnerability descriptions and compliance controls inhabit distinct semantic domains. Vulnerability descriptions discuss low-level execution semantics, hardware drivers, memory allocators, and specific application programming interfaces. Compliance controls express abstract administrative requirements, policy constraints, architectural separation, and monitoring obligations.

In recent years, the prevailing consensus across enterprise applied machine learning has favored two paradigms: deploying massive autoregressive language models for downstream reranking, and employing hybrid search architectures that fuse sparse lexical retrieval (such as BM25) with dense vector representations (Robertson and Zaragoza, 2009; Cormack et al., 2009). In this paper, we report counter-intuitive empirical results demonstrating that both prevailing strategies fail in the cross-domain compliance mapping regime.

Specifically, we demonstrate three key findings:

1. Zero-shot bi-encoder retrieval models, regardless of parameter scale, fail almost completely on technical-to-administrative mapping (achieving less than 1.0% strict retrieval accuracy).
2. Domain-specific contrastive fine-tuning using Multiple Negatives Ranking Loss (MNRL) over high-confidence vulnerability-control pairs elevates strict top-1 retrieval from 0.30% to 77.45%, generalizing to 87.15% top-3 accuracy at the parent control level.
3. Adding a 7-billion parameter generative LLM reranker degrades top-1 retrieval by 5.45 percentage points, while hybrid lexical fusion (dense plus BM25) catastrophically degrades strict top-1 retrieval to 13.65% due to lexical rank dilution.

## 2. The Semantic Disconnect

To illustrate the fundamental challenge, consider CVE-2015-1635, a well-known vulnerability in Microsoft IIS (HTTP.sys). The technical description states:

"The HTTP protocol stack (HTTP.sys) in Microsoft Windows 7 SP1, Windows Server 2008 R2 SP1, Windows 8, Windows 8.1, and Windows Server 2012 Gold and R2 allows remote attackers to execute arbitrary code via specially crafted HTTP requests."

The authoritative NIST SP 800-53 Rev 5 control for this vulnerability is SI-2 (Flaw Remediation), which mandates:

"The organization identifies, reports, and corrects information system flaws; tests software updates for effectiveness and potential side effects before installation; and installs security-relevant software updates within specified timeframes."

An alternative relevant control is SC-7 (Boundary Protection), which requires communications monitoring at system perimeters.

Between the vulnerability description and the control definition, there is zero exact word overlap regarding root-cause security taxonomy. The vulnerability disclosure mentions "protocol stack," "remote attackers," "arbitrary code," and "HTTP requests." The compliance text discusses "flaws," "software updates," "side effects," and "timeframes." Sparse lexical models searching for literal term overlap fail immediately. Standard dense embedding models trained on general web corpora, question-answering datasets, or conversational dialogue also fail, because their latent spaces correlate vulnerability texts with general software engineering or network protocols rather than regulatory governance catalogs.

### 3. Related Work

---

Dense text retrieval methods leverage bi-encoders to map queries and documents into a shared latent metric space, measuring relevance via inner product or cosine distance (Karpukhin et al., 2020; Reimers and Gurevych, 2019). Contrastive representation learning has achieved notable success across natural language benchmarks such as MTEB (Muennighoff et al., 2022). Pre-trained models such as BGE (Xiao et al., 2023) and GTE (Li et al., 2023) establish competitive baselines for retrieval tasks across broad domains.

In cross-domain applications, hybrid retrieval combining dense representations with lexical BM25 through Reciprocal Rank Fusion (RRF) is frequently recommended as a robust default (Cormack et al., 2009; Thakur et al., 2021). Furthermore, recent work in retrieval-augmented generation (RAG) emphasizes multi-stage pipelines where an initial bi-encoder retrieves candidate documents and a larger cross-encoder or autoregressive language model reranks the candidate pool (Nogueira and Cho, 2019).

Parameter-efficient fine-tuning (PEFT), particularly Low-Rank Adaptation (LoRA) (Hu et al., 2021), has enabled task-specific tuning of massive models without modifying entire parameter sets, offering protection against catastrophic forgetting. However, the comparative efficacy of fine-tuned compact bi-encoders versus large generative rerankers in highly constrained, technical-to-regulatory domains remains inadequately characterized.

### 4. Architecture and Methodology

---

The model generation stack developed in this work transforms unmapped vulnerability descriptions into ranked candidate controls through a four-stage engineering pipeline: corpus extraction, contrastive fine-tuning, validation isolation, and low-precision export.

#### 4.1 Base Encoders and Latent Spaces

Two primary encoder architectures were evaluated:

1. Local compact bi-encoder: BAAI/bge-base-en-v1.5, a 110-million parameter encoder outputting 768-dimensional dense vectors with a 512-token maximum sequence context (Xiao et al., 2023).
2. High-capacity bi-encoder: Alibaba-NLP/gte-Qwen2-7B-instruct, a 7-billion parameter bidirectional decoder-based embedding model outputting 3584-dimensional dense vectors with an 8192-token context length (Li et al., 2023).

For asymmetric retrieval, queries and target control documents were formatted with explicit task prefixes during encoding. For BGE architectures, query sentences were prefixed with: "Represent this sentence for searching relevant passages: ". For GTE-Qwen2 architectures, queries received the instruction prefix: "Instruct: Given a vulnerability description, retrieve the matching compliance control\nQuery: ", while control catalog entries were embedded without prefix formatting.

## 4.2 Contrastive Optimization with In-Batch Negatives

Fine-tuning was conducted using Multiple Negatives Ranking Loss (MNRL). Let a mini-batch of size  $N$  consist of positive pairs  $\{(\mathbf{q}_i, \mathbf{d}_i^+)\}_{i=1}^N$ , where  $\mathbf{q}_i$  represents the dense embedding of vulnerability description  $i$ , and  $\mathbf{d}_i^+$  represents the dense embedding of the authoritative NIST control text corresponding to query  $i$ .

The loss for sample  $i$  is formulated as the negative log-likelihood of the true positive document relative to all positive documents present in the mini-batch:

$$\mathcal{L}_i = -\log \frac{\exp(\text{sim}(\mathbf{q}_i, \mathbf{d}_i^+)/\tau)}{\sum_{j=1}^N \exp(\text{sim}(\mathbf{q}_i, \mathbf{d}_j^+)/\tau)}$$

where  $\text{sim}(\mathbf{u}, \mathbf{v}) = \frac{\mathbf{u} \cdot \mathbf{v}}{\|\mathbf{u}\|_2 \|\mathbf{v}\|_2}$  denotes cosine similarity, and  $\tau$  denotes a temperature hyperparameter.

The in-batch negative design is critical for regulatory mapping. In a mini-batch of size 32, each vulnerability query is contrasted against one ground-truth control and 31 negative controls. The gradient simultaneously pulls the vulnerability vector toward its legitimate regulatory control and repels it from unrelated controls across other security families (such as Access Control, Audit and Accountability, or Incident Response). This multi-directional pressure regularizes the latent space and prevents embedding collapse.

## 4.3 Low-Rank Adaptation (LoRA) for Decoder-Based Embeddings

To fine-tune the 7-billion parameter GTE-Qwen2 model without inducing catastrophic forgetting or requiring prohibitive computational clusters, Low-Rank Adaptation was applied (Hu et al., 2021). All base transformer parameters were frozen. Trainable rank decomposition matrices were attached to the query, key, value, output, and multi-layer perceptron projection layers:

$$\mathbf{W} = \mathbf{W}_0 + \frac{\alpha}{r} \mathbf{B} \mathbf{A}$$

where  $\mathbf{W}_0 \in \mathbb{R}^{d \times k}$  represents the frozen base weight matrix,  $\mathbf{B} \in \mathbb{R}^{d \times r}$ ,  $\mathbf{A} \in \mathbb{R}^{r \times k}$ ,  $r = 64$ ,  $\alpha = 128$ , and dropout was set to 0.05. This configuration reduced trainable parameters to less than 2% of the base model while allowing extensive adaptation of the latent projection space.

## 4.4 Data Contamination Safeguards and Validation Isolation

A critical vulnerability in machine learning evaluations for compliance tooling is data leakage between pre-computed seeds and validation benchmarks. To establish an inviolable validation gate, an independent golden evaluation suite comprising 2,000 unique vulnerability records was constructed prior to training.

Each record in the validation set contains a unique CVE identifier, its full technical text, and the ground-truth NIST SP 800-53 control resolved via authoritative human adjudication. All training scripts explicitly parse this golden dataset and purge matching CVE identifiers from the training partition before initiating model training.

## 5. Experimental Evaluation and Benchmarks

### 5.1 Evaluation Metrics

Candidate models were evaluated across six retrieval metrics:

1. Strict Hit Rate @ 1 (Strict HR@1): Percentage of queries where the top-ranked retrieved control exactly matches the ground-truth control identifier.
2. Strict Hit Rate @ 3 (Strict HR@3): Percentage of queries where the ground-truth control is present among the top three candidates.
3. Strict Mean Reciprocal Rank (Strict MRR): Mean of reciprocal ranks of the correct control across all queries:

$$\text{MRR} = \frac{1}{|Q|} \sum_{i=1}^{|Q|} \frac{1}{\text{rank}_i}$$

4. Parent Roll-up Hit Rate @ 1 (Parent HR@1): Percentage of queries where the top retrieved control belongs to the same parent control family (e.g., matching SI-2 when the ground truth is SI-2(1)).
5. Parent Roll-up Hit Rate @ 3 (Parent HR@3): Presence of the parent control family in the top three retrieved candidates.
6. Parent Roll-up MRR: Mean reciprocal rank evaluated at the parent control level.

The parent roll-up metrics reflect practical compliance workflows, where identifying the correct parent control family still provides immediate utility to compliance auditors.

### 5.2 Comparative Results

Models were benchmarked against the 2,000-sample golden validation dataset. Table 1 reports the comparative evaluation across zero-shot baselines and fine-tuned architectures.

**Table 1.** Retrieval benchmarks on the 2,000-item isolated golden validation set. All models evaluated against the full NIST SP 800-53 Rev 5 catalog (1,196 controls).

| Model Architecture                | Strict HR@1 | Strict HR@3 | Strict MRR | Parent HR@1 | Parent HR@3 | Parent MRR |
|-----------------------------------|-------------|-------------|------------|-------------|-------------|------------|
| gte-Qwen2-7B-instruct (Zero-Shot) | 0.10%       | 0.40%       | 0.0030     | 0.40%       | 1.10%       | 0.0070     |
| bge-large-en-v1.5 (Zero-Shot)     | 0.30%       | 0.90%       | 0.0050     | 8.40%       | 18.60%      | 0.1270     |
| bge-base-en-v1.5 (Fine-Tuned)     | 77.45%      | 82.15%      | 0.7947     | 81.95%      | 87.15%      | 0.8422     |

As demonstrated in **Table 1**, pre-trained foundation models in zero-shot configurations are virtually incapable of solving the compliance mapping problem. Zero-shot BGE-Large achieved a Strict HR@1 of 0.30%, while zero-shot GTE-Qwen2-7B achieved 0.10%. These figures confirm that generic pre-training does not align vulnerability semantics with regulatory controls.

In contrast, fine-tuning the compact BGE-Base model for 3 epochs using Multiple Negatives Ranking Loss increased Strict HR@1 by 77.15 percentage points to 77.45%, while Strict HR@3 reached 82.15% and Parent Roll-

up HR@3 reached 87.15%. Training completed in 1 hour and 41 minutes on a single consumer GPU (NVIDIA RTX 2080 Super).

## 6. Empirical Analysis of Failed Architectures

To explore whether retrieval precision could be further enhanced, two widely adopted techniques were implemented and rigorously tested: generative LLM reranking and sparse-dense hybrid retrieval. Both techniques caused notable performance degradation.

### 6.1 Downstream Generative LLM Reranking Degradation

In modern retrieval architectures, bi-encoders are frequently used as coarse first-stage retrievers, followed by an autoregressive LLM to rerank candidate documents. To test this design, the fine-tuned BGE-Base model was used to retrieve the top 10 candidate controls for each vulnerability description. A generative model, Qwen2.5-7B-Instruct (served locally at temperature 0.0), was supplied with the technical vulnerability summary and the 10 candidate control texts, prompted to rank the options by compliance relevance.

Evaluated over 100 validation samples, downstream LLM reranking degraded retrieval performance across all strict metrics, as detailed in **Table 2**.

**Table 2.** Impact of downstream LLM reranking (Qwen2.5-7B-Instruct) on first-stage fine-tuned dense retrieval candidates.

| Pipeline Configuration            | Strict HR@1 | Strict HR@3 | Strict MRR | Parent HR@1 | Parent HR@3 | Parent MRR |
|-----------------------------------|-------------|-------------|------------|-------------|-------------|------------|
| Fine-Tuned BGE-Base (Raw)         | 77.45%      | 82.15%      | 0.7947     | 81.95%      | 87.15%      | 0.8422     |
| Fine-Tuned BGE + Qwen2.5 Reranker | 72.00%      | 80.00%      | 0.7600     | 82.00%      | 86.00%      | 0.8400     |

Strict HR@1 decreased from 77.45% to 72.00%, and Strict MRR decreased from 0.7947 to 0.7600. Qualitative examination of the failure cases revealed that the generative LLM over-indexed on secondary textual cues. When presented with vulnerability descriptions mentioning web interfaces or network endpoints, the generative model frequently prioritized boundary controls (such as SC-7 Boundary Protection) over the precise functional flaw remediation controls (such as SI-2 Flaw Remediation), overriding the mathematically disciplined geometric distance learned by the contrastive bi-encoder.

### 6.2 Lexical Hybrid Search Collapse

Hybrid search combining dense vector similarity with sparse BM25 keyword matching via Reciprocal Rank Fusion (RRF,  $k = 60$ ) is widely regarded as a best practice for enterprise search (Robertson and Zaragoza, 2009; Cormack et al., 2009). The top 50 dense candidates and top 50 BM25 candidates were retrieved from the 1,196-control catalog and fused:

$$\text{RRF\_Score}(d) = \sum_{m \in \{\text{dense}, \text{sparse}\}} \frac{1}{k + \text{rank}_m(d)}$$

The fused candidates were evaluated against the full 2,000-sample validation set. The results are summarized in **Table 3**.

**Table 3.** Comparison of pure dense retrieval versus hybrid dense-plus-lexical search (Dense + BM25 Okapi with Reciprocal Rank Fusion).

| Retrieval Architecture           | Strict HR@1 | Strict HR@3 | Strict MRR | Parent HR@1 | Parent HR@3 | Parent MRR |
|----------------------------------|-------------|-------------|------------|-------------|-------------|------------|
| Fine-Tuned BGE-Base (Pure Dense) | 77.45%      | 82.15%      | 0.7947     | 81.95%      | 87.15%      | 0.8422     |
| Hybrid Dense + BM25 (RRF k=60)   | 13.65%      | 58.10%      | 0.3305     | 21.95%      | 66.25%      | 0.4155     |

As shown in **Table 3**, hybrid search caused catastrophic performance collapse. Strict HR@1 fell from 77.45% to 13.65%, and Strict MRR dropped from 0.7947 to 0.3305.

The mechanism driving this failure is lexical rank poisoning. Because vulnerability disclosures describe operational attack surfaces and software bugs, while compliance catalogs specify administrative mandates, the true matching control rarely shares substantial verbatim vocabulary with the query. Consequently, BM25 returns arbitrary, noisy matches driven by incidental stopword co-occurrences or generic vocabulary (such as "system," "access," or "information"). Because RRF allocates substantial weight to top-ranked sparse returns, these irrelevant lexical candidates pushed the high-precision dense matches down the ranked list, corrupting the final recommendations.

## 7. Deployment Engineering and Production Optimization

In mission-critical defense and enterprise environments, compliance evaluation systems must frequently operate in air-gapped, resource-constrained, or edge deployments without connectivity to external cloud APIs.

To support edge deployment:

1. GGUF Quantization: Fine-tuned Hugging Face transformer weights were converted to GGUF format using llama.cpp and quantized to 8-bit precision (Q8\_0). This reduced the model memory footprint to under 150 megabytes with negligible loss in retrieval fidelity.
2. In-Process Native Execution: The quantized GGUF model is loaded directly into the host runtime using native C++ bindings (LLamaSharp), eliminating the need for auxiliary Python sidecar processes or network hops during inference.
3. Pre-Computed Latent Caching: The 1,196 NIST control catalog embeddings were pre-computed and stored on disk. At system initialization, the control index is loaded into an in-memory vector matrix in under 5 milliseconds. Incoming vulnerability queries are encoded on-demand and evaluated via vectorized inner product operations, delivering sub-millisecond per-vulnerability mapping latency.

## 8. Continuous Retraining and Overfitting Safeguards

---

When deployed operationally, the compliance mapping engine captures human adjudications as security officers review and approve mapping recommendations. To incorporate this continuous operational feedback without inducing regression, three safeguards were codified:

1. **Ranked Deduplication:** When conflicting mappings exist for identical vulnerabilities across different operational units, strict relational precedence is enforced at query time (system-locked mappings take precedence over individual user overrides). This eliminates contradictory positive pairs that destabilize contrastive gradients.
2. **Epoch Clamping and Warmup:** Contrastive fine-tuning is strictly restricted to 3 epochs with a 50-step linear learning rate warmup. In dense vector fine-tuning, training beyond 3 epochs leads directly to sample memorization and loss of generalization across unseen CVE phrasings.
3. **Automated Validation Gating:** Any scheduled retraining cycle automatically executes the validation suite against the isolated 2,000-sample golden set. Model weights are committed to production if and only if validation metrics meet or exceed the established baseline (Strict HR@1  $\geq$  77.45%). Degraded weights are rejected automatically.

## 9. Conclusion

---

This research demonstrates that domain-specific contrastive representation learning provides an accurate, robust, and computationally compact solution to the cross-domain compliance mapping problem. While contemporary industry practice routinely gravitates toward generative LLM reranking and hybrid lexical search, our empirical findings demonstrate that both paradigms degrade retrieval precision in the technical-to-regulatory domain. A compact 110-million parameter encoder, fine-tuned with Multiple Negatives Ranking Loss, achieved an 82.15% strict top-3 accuracy and an 87.15% parent roll-up accuracy, while executing at sub-millisecond latency on standard commodity hardware.

## Open-Source Availability

---

To advance reproducibility and assist organizations navigating regulatory cybersecurity frameworks, the complete model generation stack, training scripts, LoRA adapter configurations, evaluation datasets, and GGUF conversion utilities have been open-sourced under the Apache 2.0 license. The repository is available through the Applied Inference Lab organization at: <https://github.com/applied-inference-lab/autormf-ml-lab>

## References

---

- Cormack, G. V., Clarke, C. L. A., and Büttcher, S. (2009). Reciprocal rank fusion outperforms Condorcet and individual rank learning methods. In *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, pages 758-759.
- Hu, E. J., Shen, Y., Wallis, P., Allen-Zhu, Z., Li, Y., Wang, S., Wang, L., and Chen, W. (2021). LoRA: Low-rank adaptation of large language models. *arXiv preprint arXiv:2106.09685*.
- Joint Task Force (2020). *Security and Privacy Controls for Information Systems and Organizations*. NIST Special Publication 800-53, Revision 5. National Institute of Standards and Technology, Gaithersburg, MD.

- Karpukhin, V., Oguz, B., Min, S., Lewis, P., Wu, L., Edunov, S., Chen, D., and Yih, W.-t. (2020). Dense passage retrieval for open-domain question answering. In *Proceedings of the 2020 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, pages 6769-6781.
- Li, Z., Zhang, X., Zhang, Y., Long, D., Xie, P., and Zhang, M. (2023). Towards general text embeddings with multi-stage contrastive learning. *arXiv preprint arXiv:2308.03281*.
- Muennighoff, N., Tazi, N., Magne, L., and Reimers, N. (2023). MTEB: Massive text embedding benchmark. In *Proceedings of the 17th Conference of the European Chapter of the Association for Computational Linguistics (EACL)*, pages 2014-2037.
- National Institute of Standards and Technology (2026). National Vulnerability Database (NVD). U.S. Department of Commerce. Available at: <https://nvd.nist.gov/> (Accessed: Aug/Sept 2026).
- Nogueira, R., and Cho, K. (2019). Passage re-ranking with BERT. *arXiv preprint arXiv:1901.04085*.
- Reimers, N., and Gurevych, I. (2019). Sentence-BERT: Sentence embeddings using Siamese BERT-networks. In *Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, pages 3982-3992.
- Robertson, S., and Zaragoza, H. (2009). The probabilistic relevance framework: BM25 and beyond. *Foundations and Trends in Information Retrieval*, 3(4):333-389.
- Thakur, N., Reimers, N., Rücklé, A., Srivastava, A., and Gurevych, I. (2021). BEIR: A heterogeneous benchmark for zero-shot evaluation of information retrieval models. In *Thirty-fifth Conference on Neural Information Processing Systems (NeurIPS) Datasets and Benchmarks Track*.
- Xiao, S., Liu, Z., Zhang, P., and Muennighoff, N. (2023). C-pack: Packaged resources to advance general Chinese embedding. *arXiv preprint arXiv:2309.07597*.